INCIDENT INVESTIGATION REPORT

Security Operations Center (SOC) | Internal Confidential

1. Executive Summary

On **March 7, 2024**, at approximately **11:44AM**, the SOC triggered an alert regarding a brute-force attack, targeting the workstation **"Matthew" (172.16.17.148)**.Investigation confirmed that it was a successful unauthorized access incident where the attack originated from **Source IP (218.92.0.56)** from location Jiangsu, China via **Remote Desktop Protocol(RDP)**.The host was successfully isolated within 30 minutes of initial detection, preventing further lateral movement. No sensitive data exfiltration was observed.

2. Incident Metadata

Incident ID	INC-2026-234
Report Date	March 7, 2024
Incident Category	Unauthorized access – Brute Force
Severity Level	High
Assigned Analyst	Kesha Patel
Status	Contained

3. Target & Attacker Information

Affected Asset	Matthew (Workstation)
Target IP Address	172.16.17.148
Attacker Source IP	218.92.0.56
Attacker Geolocation	Jiangsu, China
Associated ISP	Chinanet
Threat Actor type	Automated Botnet (Suspected)

4. Investigation Timeline

11:44 AM: The attacker started by trying to guess common usernames like admin and guest. These failed and triggered Event ID 4625 (logon failure). Because they used so many different ports (like 11845 and 51707) all at once, it's clear they were using an automated tool to scan the system.

11:44 AM: During this same minute, the Firewall blocked several other connection attempts from the same attacker before they could even try to log in.

11:44 AM: The attacker didn't stop and tried the admin and guest accounts again, but those failed a second time.

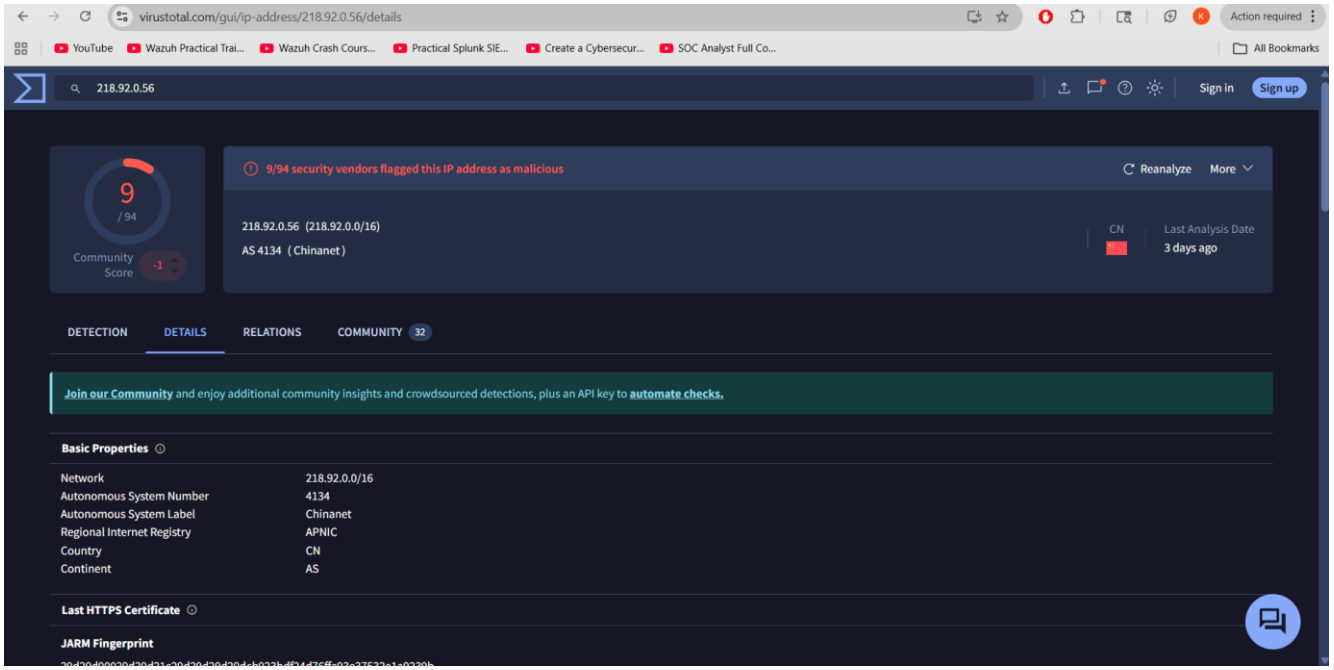
11:44 AM: Next, they tried to get into the sysadmin account using several different source ports, but this also triggered failure alerts.

11:44 AM: The attacker then moved on to more specific usernames and guessed Matthew. At first, they got the username right but the password wrong.

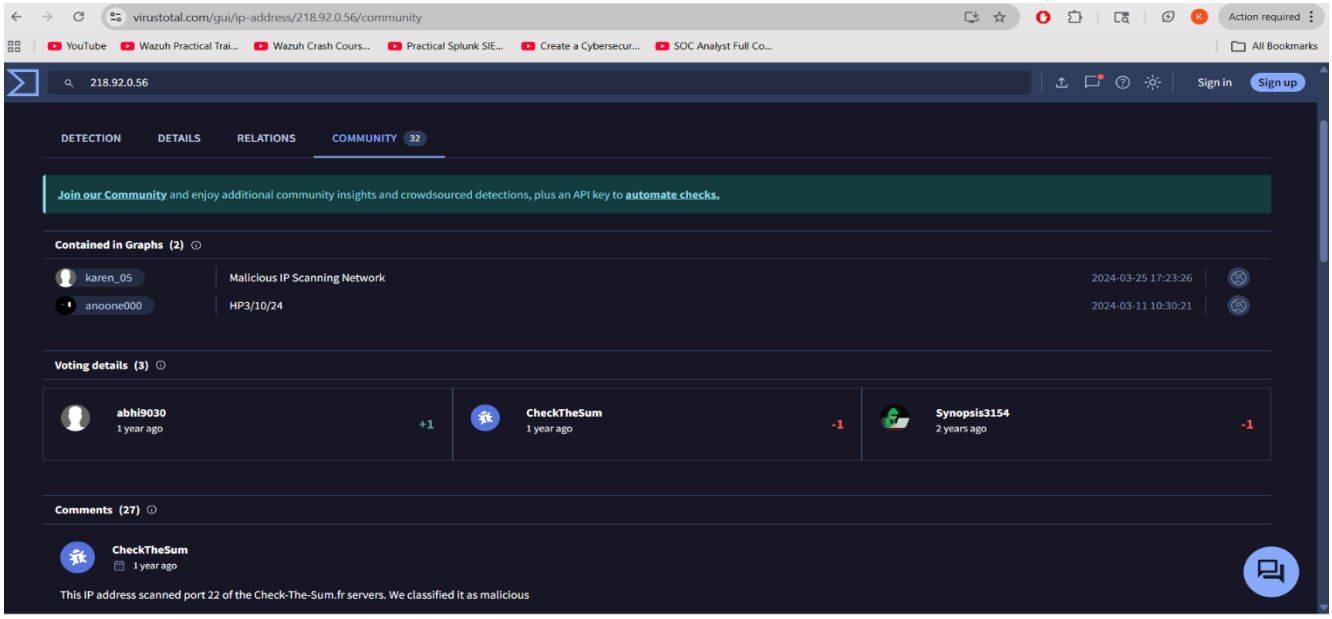
11:44 AM: After a few more tries, the attacker successfully guessed the password for Matthew's account. Event ID 4624 was recorded, meaning they were officially logged into the computer.

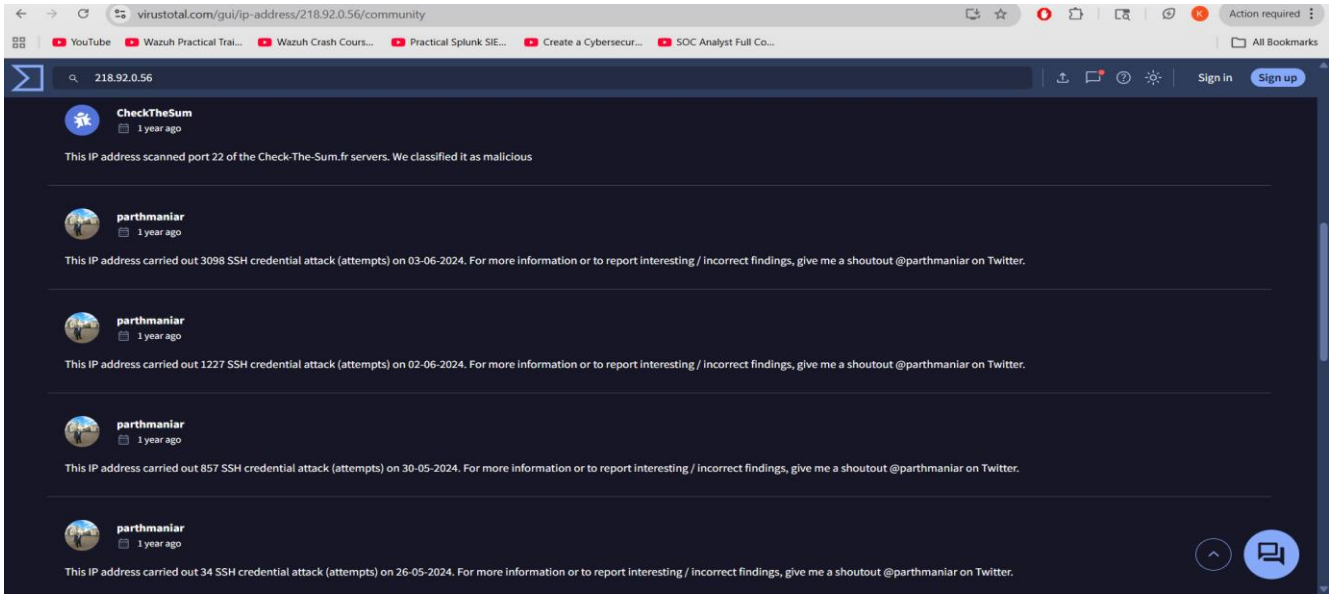
5. Evidence (Artifacts)

1. Threat Intelligence (Virustotal):

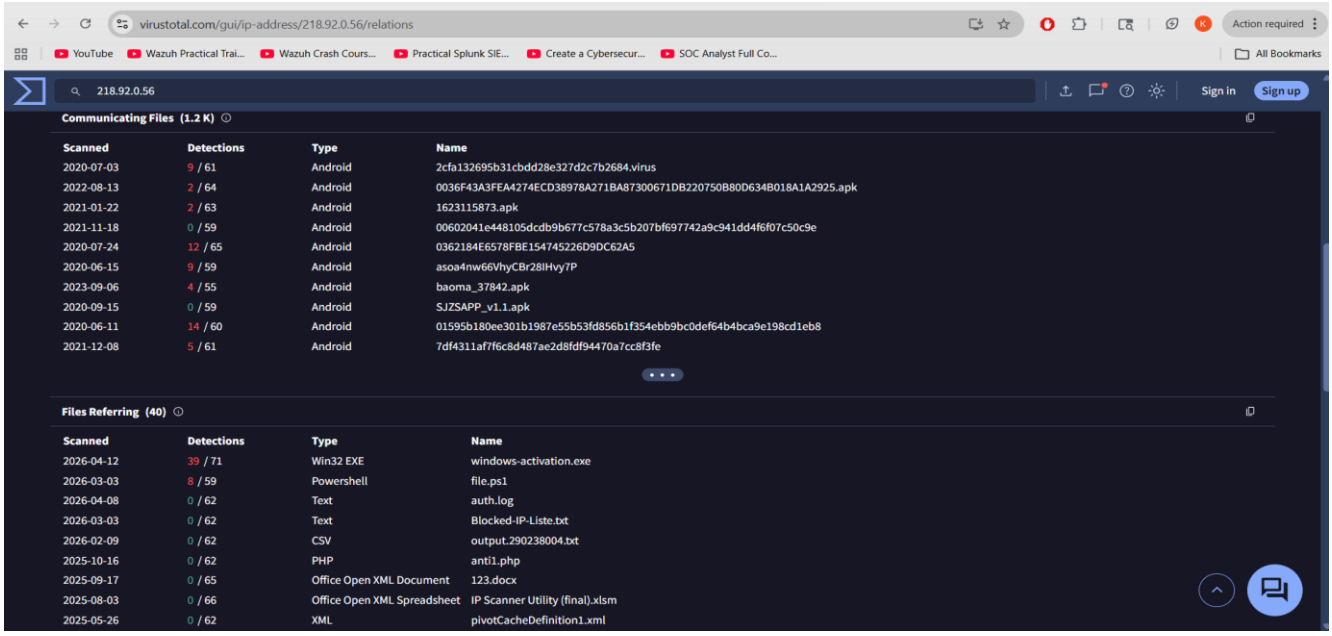


The score shows a 9/94 and community score as -1 which means we are not sure if this is malicious, so we need to go a little deep





The community tab shows multiple people reporting this IP as malicious. The comments link IP **218.92.0.56** to a known botnet and over 3000 SSH attacks.



Relations tab – Showing IP communicates with malicious Android APKs and the windows-activation.exe shows a detection score of 39/71 which means it is malicious.

YouTube | Wazuh Practical Trai... | Wazuh Crash Cours... | Practical Splunk SIE... | Create a Cybersecur... | SOC Analyst Full Co... | All Bookmarks

218.92.0.56 | Sign in | Sign up

Basic Properties

Network	218.92.0.0/16
Autonomous System Number	4134
Autonomous System Label	Chinanet
Regional Internet Registry	APNIC
Country	CN
Continent	AS

Last HTTPS Certificate

JARM Fingerprint

29d29d00029d29d21c29d29d29d29dcb923bdf24d76ffa93e37532e1a9239b

Last HTTPS Certificate

```
Data:
  Version: V3
  Serial Number: 4bad8cbd67f0a240fd0c49a9
  Thumbprint: f6d8a8fcfd52c3b742ebae02e908e0af3cc61705
Signature Algorithm: sha256RSA
  Issuer: C=BE , CN=GlobalSign Organization Validation CA - SHA256 - G2 , O=GlobalSign nv-sa
  Validity
    Not Before: 2020-08-11 03:36:08
    Not After: 2021-08-12 03:36:08
  Subject: CN=*.alicdn.com , C=CN , L=HangZhou , O=Alibaba (China) Technology Co., Ltd. , ST=ZheJiang
  Subject Public Key Info:
    Public Key Algorithm : RSA
      Public-Key: (2048 bit)
      Modulus:
        00:ae:c6:a9:8a:fd:72:39:89:98:53:82:05:65:78:
```

YouTube | Wazuh Practical Trai... | Wazuh Crash Cours... | Practical Splunk SIE... | Create a Cybersecur... | SOC Analyst Full Co... | All Bookmarks

218.92.0.56 | Sign in | Sign up

Registration Data (RDAP)

Entity CJ186-AP

Handle:

CJ186-AP

Roles:

- technical

Remarks:

send anti-spam reports tojsipmanager@163.comsend abuse reports tojsipmanager@163.comtimes in GMT+8www.jsinfo.net

Links:

- https://rdap.apnic.net/entity/CJ186-AP

Conformance:

- history_version_0
- nro_rdap_profile_0
- cidr0
- rdap_level_0

Whois Lookup

```
last-modified: 2022-08-05T15:34:47Z
source: APNIC
person: Chinanet Hostmaster
nic-hdl: CH93-AP
e-mail: anti-spam@chinatelecom.cn
address: No.31 ,jingrong street,beijing
```

YouTube | Wazuh Practical Trai... | Wazuh Crash Cours... | Practical Splunk SIE... | Create a Cybersecur... | SOC Analyst Full Co... | All Bookmarks

218.92.0.56 | Sign in | Sign up

- nro_rdap_profile_0
- cidr0
- rdap_level_0

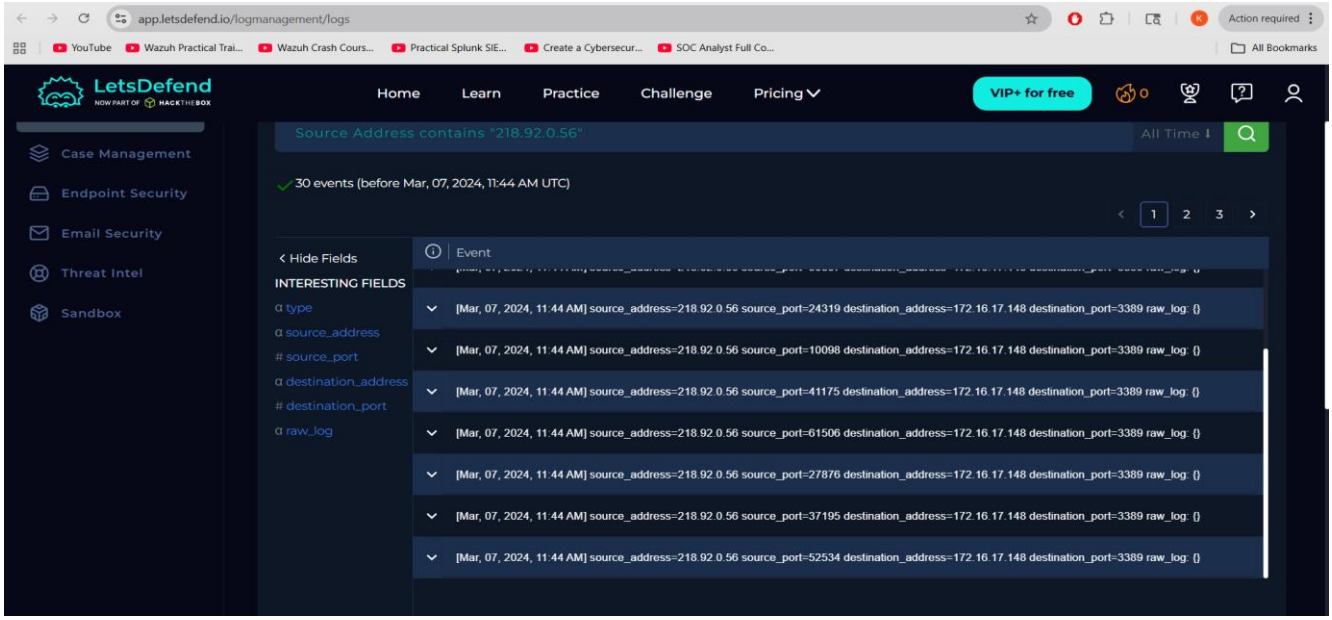
Whois Lookup

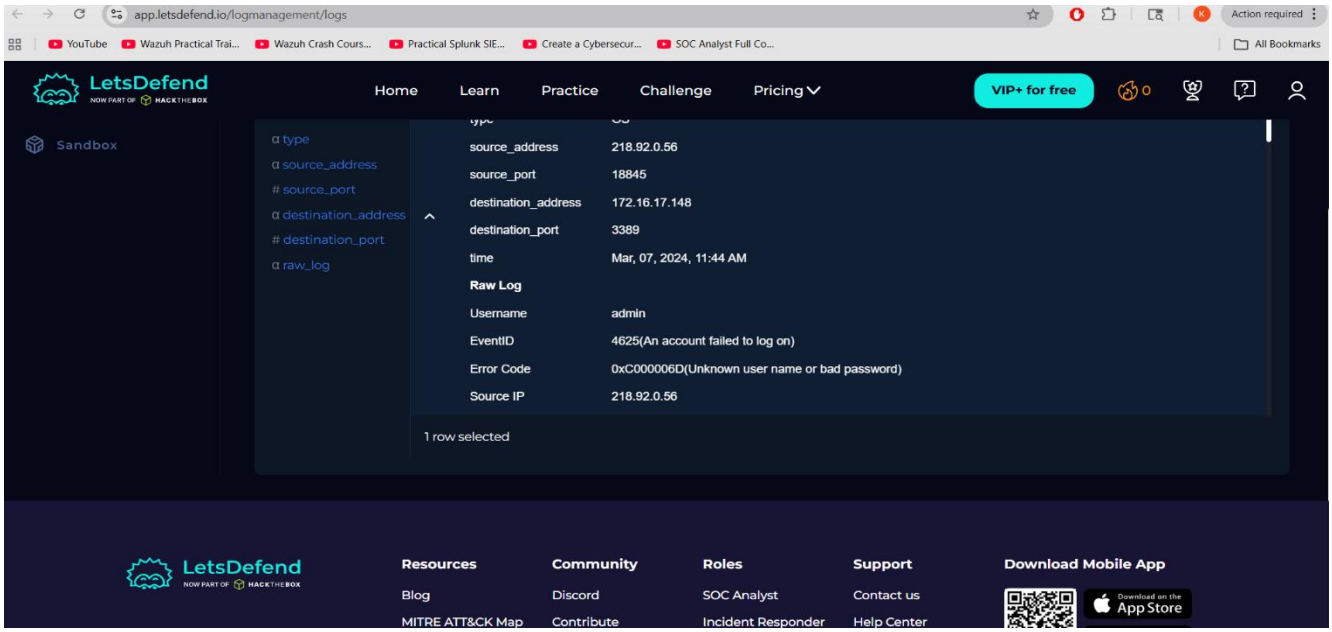
```
last-modified: 2022-08-05T15:34:47Z
source: APNIC
person: Chinanet Hostmaster
nic-hdl: CH93-AP
e-mail: anti-spam@chinatelecom.cn
address: No.31 ,jingrong street,beijing
address: 100032
phone: +86-10-58501724
fax-no: +86-10-58501724
country: CN
mnt-by: MAINT-CHINANET
last-modified: 2022-02-28T06:53:44Z
source: APNIC
route: 218.92.0.0/16
descr: CHINANET jiangsu province network
origin: AS4134
mnt-by: MAINT-CHINANET-JS
last-modified: 2019-02-14T06:59:43Z
source: APNIC
```

Google results

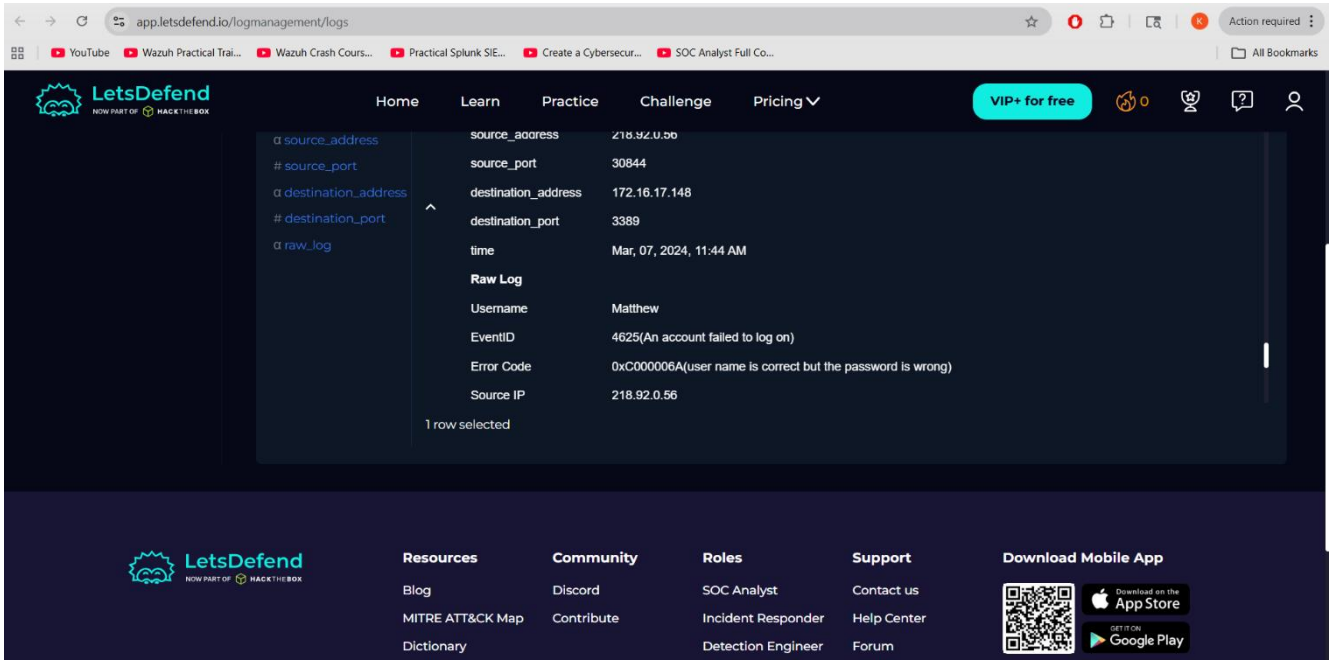
About 36 results (0.18 seconds) | Sort by

Details tab - IP belongs to Chinanet. IP is in Jiangsu, China. Target server is not located in China and doesn't have employees there. So, this proves that the IP is malicious and the incident is a True positive.

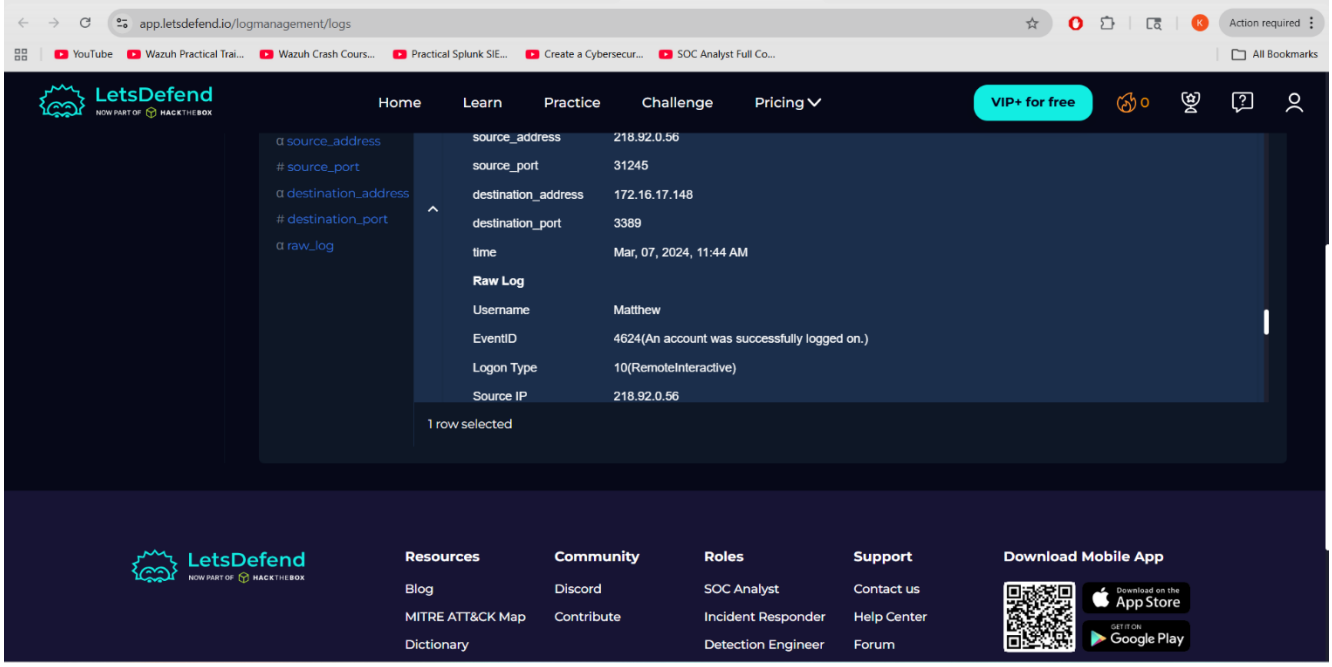




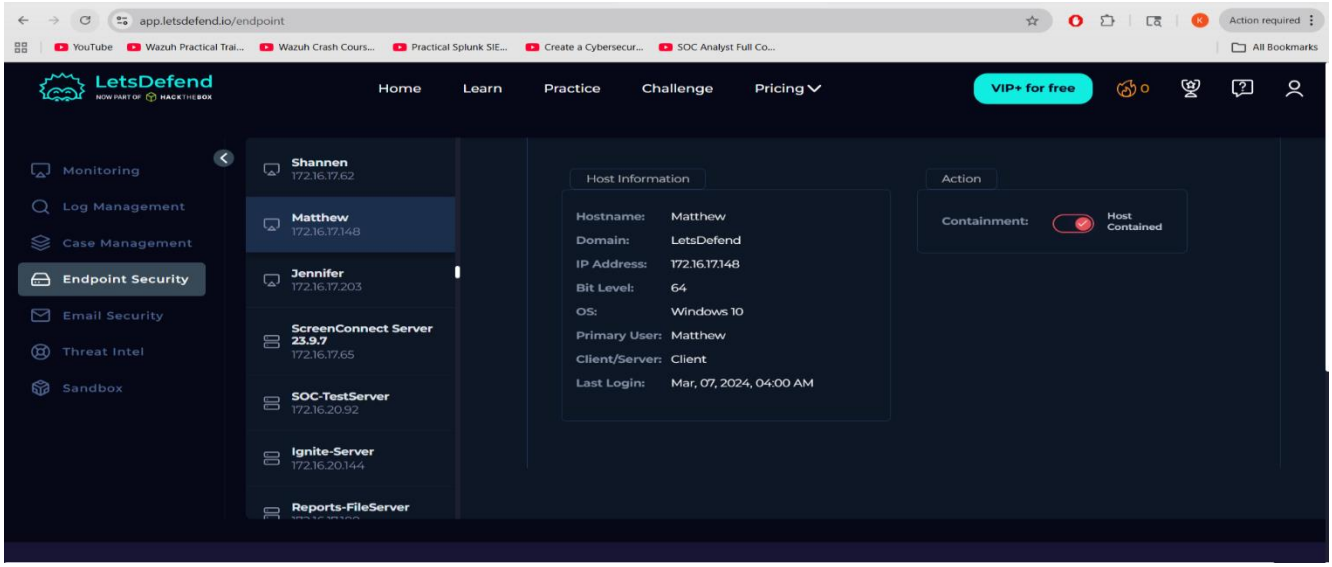
Failed login for admin account.



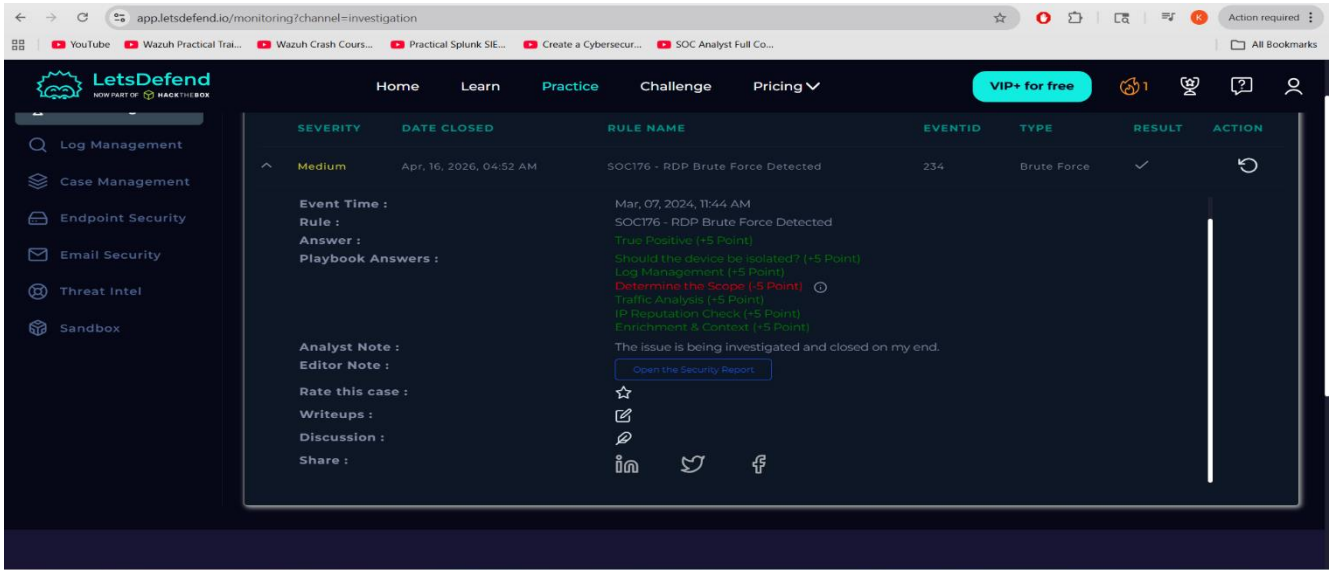
Attacker trying to guess the specific username and password where he/she got successful at guessing the username.



The attacker successfully logged in for the Matthew account. Logon type 10 confirms the access was via RDP.



After the detection, the host was isolated.



The Summary of the findings.

6. Recommendations & Remediation

Short-Term actions:

1. Proactive Monitoring: Setting up a failed login threshold alert in your SIEM to stop the brute force before it succeeds.
2. Account Lockout policy: This can be changes in Group policy. It stops automated scripts from guessing thousands of passwords by locking them out after the set number of failures (e.g. 5 or 10).
3. Network: Close port 3389 immediately to public Internet to prevent further damage.

Long-Term actions:

1. MFA implementation: Enable Multi Factor Authentication for all the logins.
2. Password Complexity: Enforce long, complex passphrases to prevent brute-force.
3. VPN: set up a secure VPN gateway for all remote access.